Ecole Supérieure d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE

Introduction to Cybersecurity

PRESENTED BY:
SEBBAR ANASS

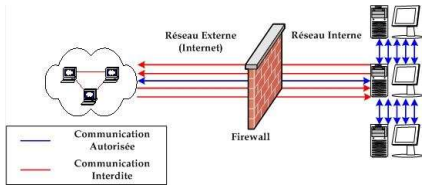
Année universitaire: 2024-2025

1

1

Qu'est ce qu'un firewall ?

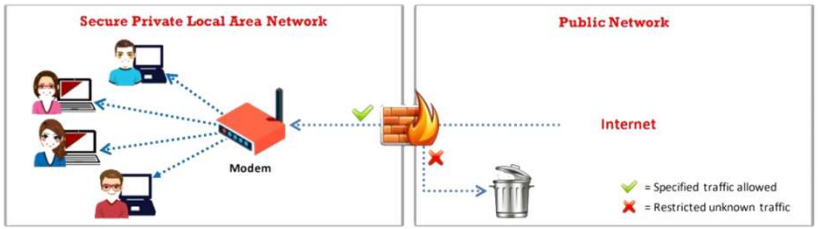
- Un firewall est essentiellement un dispositif de protection qui constitue un filtre entre un réseau local et un autre réseau non sûr tel que l'Internet ou un autre réseau local.



2

Firewall

- Firewalls are hardware and/or software designed to prevent **unauthorized access** to or from a private network
- They are placed at the junction or **gateway** between two networks, which is usually between a private network and a public network such as the Internet
- Firewalls **examine all messages entering or leaving the Intranet** (or private network) and block those that do not meet the specified security criteria



3

Objectifs d'un firewall

Les firewalls visent, au niveau de la sécurité, deux objectifs:

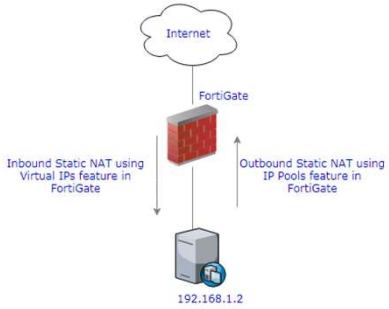
1. Contrôler et protéger les hôtes du réseau local: Contre la divulgation non autorisée d'informations sensibles
2. Protéger les serveurs Internet
   - Contre des commandes jugées dangereuses associées à des services du type « telnet » et « sendmail » autre
   - Contre la modification ou la suppression non autorisée de fichiers vitaux pour le système

4

4

Firewall principes de base

- Moindre privilège
- Défense en profondeur
- Goulet d'étranglement
- Interdiction par défaut
- Participation de l'utilisateur
- Simplicité



5

Principes de base d'un firewall

- Le moindre privilège :
  - Octroyer le moindre privilège aux utilisateur (processeurs) pour réaliser leur tâches.

  ==>**Objectif**: limiter les conséquences d'une vulnérabilité ou d'une erreur.
- La défense en profondeur :
  - Utilisation de plusieurs mécanismes de protection redondants

  ==>**Objectif** : Garder une défense efficace même si un des mécanismes de défense devait être vulnérable ou mal configuré (ex. désactivé les services non utilisés)
- Le goulet d'étranglement
  - Le trafic doit passer par un seul point : le FireWall

  ==> **Objectif** : Toute attaque doit passer par un chemin connu où il peut être bloquée (ex. utilisation de modems)

6

Firewall Interdiction par défaut

Interdire par défaut tout transit à travers le pare feu et ne laissé passé que celui qui est explicitement autorisé, évitant ainsi tout transit involontairement accepté .

Pourquoi?

- Nous ne pouvons jamais savoir à l'avance toutes les menaces auxquelles nous serons exposer
- Si nous faisons une erreur, il est préférable d'interdire quelque chose d'utile que de permettre une attaque.

7

Firewall Participation de l'utilisateur

Les utilisateur doivent être impliqués dans la mise en place du pare feu. Ils doivent en effet exprimer leurs besoins et recevoir en échange les raisons et les objectifs de l'installation d'un tel dispositif:

- Les contraintes du pare feu seront acceptées

Nous devons comprendre les besoins de l'utilisateur et s'assurer que les raisons de restrictions sont bien mis dans

8

Firewall Simplicité

Les règles de filtrage du pare feu doivent être les plus simples et donc les plus compréhensibles possible afin d'éviter toute erreur de la part de l'administrateur et de ses successeurs

Dans un système avec des règles de filtrage simples:

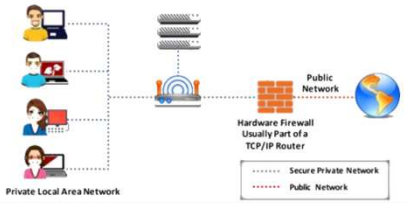
- Le risque d'erreur est plus petit
- Il est plus facile de vérifier son bon fonctionnement

9

Types of Firewalls

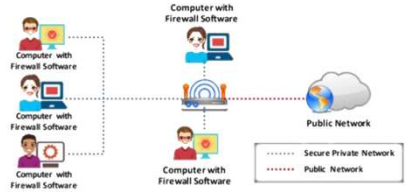
Hardware Firewalls

- A hardware firewall is either a dedicated stand-alone hardware device or it comes as part of a router
- The network traffic is filtered using the packet filtering technique
- It is used to filter out the network traffic for large business networks



Software Firewalls

- A software firewall is a software program installed on a computer, just like normal software
- It is generally used to filter traffic for individual home users
- It only filters traffic for the computer on which it is installed, not for the entire network



Note: It is recommended that you configure both a software and a hardware firewall for best protection

10

Firewall Logiciel ou matériel

Un pare-feu logiciel hérite toutes les vulnérabilités du système d'exploitation sur lequel ils s'éxécute

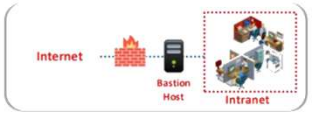
L' architectures du pare-feu logiciel est connu, donc c'est plus facile à exploiter ses vulnérabilités

11

Firewall Architecture

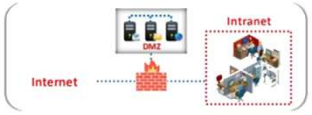
Bastion Host

- A bastion host is a computer system designed and configured to protect network resources from attacks
- Traffic entering or leaving the network passes through the firewall. It has two interfaces:
  - a public interface directly connected to the Internet
  - a private interface connected to the Intranet



Screened Subnet

- The screened subnet or Demilitarized Zone (DMZ) contains hosts that offer public services
- The DMZ responds to public requests, and has no hosts accessed by the private network
- This private zone can not be accessed by Internet users



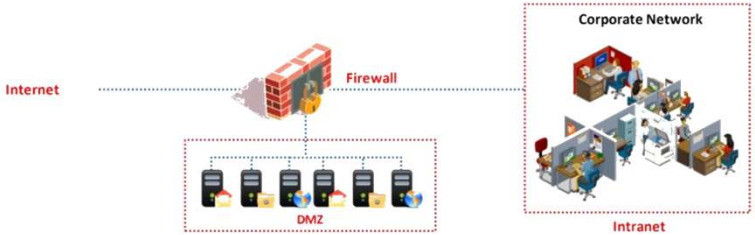
Multi-homed Firewall

- In this case, a firewall with two or more interfaces is present that allows further subdivision of the network based on the specific security objectives of the organization

12

Demilitarized Zone (DMZ)

- The DMZ is a network that **serves as a buffer** between the internal secure network and the insecure Internet
- It can be created **using a firewall with three or more network interfaces**, assigned with specific roles such as the internal trusted network, the DMZ network, and the external un-trusted network



13

Firewall Technologies

- Firewalls are designed and developed with the help of different **firewall services**
- Each firewall service provides security, depending on its **efficiency** and **sophistication**

Technologies used for creating a firewall service

1. Packet Filtering
2. Circuit Level Gateways
3. Application Level Firewall
4. Stateful Multilayer Inspection
5. Application Proxies
6. Network Address Translation
7. Virtual Private Network

14

Mode de Firewall

Firewall sans mémoire (statless)
- Ne se souvient pas des paquets qu'il a déjà vu

Firewall avec mémoire (Statfull)
- Garde une trace des paquets qui passent par lui.
- Reconstruit l'état de chaque connexion

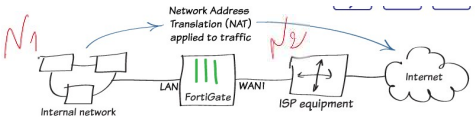
Firewall NG
- Intègre une inspection approfondie et des fonctionnalités avancées.

Firewall application
- Analyse le trafic en fonction du contenu et des applications.

15

NAT (Network Address Translation)

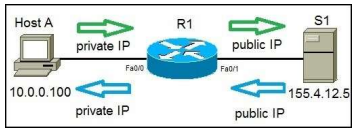
- Une passerelle (**routeur/gateway**) est dotée de deux interfaces :
  - L'une d'elle appartient au **réseau N°1**
  - La deuxième interface est connectée au deuxième réseau (avec une adresse faisant partie des adresses du **2ème réseau**).
- Tout le trafic traversant le passerelle et orienté **vers** le 2ème réseau est doté de l'adresse IP source de 2ème interface
- Tout le trafic entrant vers le 1er réseau **doit être doté** de l'adresse IP de destination la 2ème interface
- Utilisation des adresses non routables ou non enregistrées [10.0.0] ou [172.16.0.0 à 172.31.0.0] ou [192.168.0.0]



16

Types of NAT

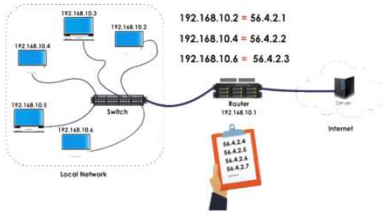
- **Static NAT (SNAT)** — A type of network where one private address is mapped with one public IP address. These IP addresses never change
  - SNAT allows internal hosts/servers to have a private IP address and still access the internet. But this kind of setup is wasteful of expensive public IPs. SNAT deals more with incoming traffic.



17

Types of NAT

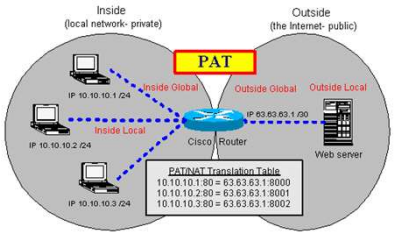
- **Dynamic NAT (DNAT)** — The mapping of an internal private IP address into the router's public IP is dynamic. This is also called **IP masquerading**. The outgoing traffic carries "**a"** public IP of the router. When data comes in, it is looked upon in the NAT table for its destination address.



18

Types of NAT

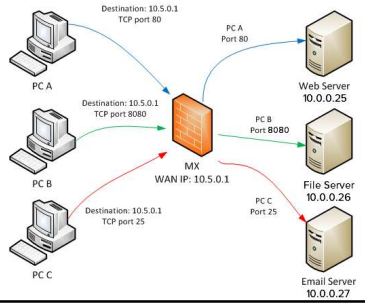
- **Port Address Translation (PAT)** — Each host on a LAN has its IP address translated into the router's WAN side IP **with a different port number**. This makes each session unique. It is the most common form of NAT. There are a total of 65536 ports.



19

Types of NAT

- **Port Forwarding —** Deals more with incoming traffic. It is used when a single public IP address works with several public servers.



20

The differences between SNAT and DNAT

Source NAT (SNAT)	Destination NAT (DNAT)
SNAT stands for **Source NAT**.	DNAT stands for Destination NAT.
Here, Private IP address **is converted into** Public IP.	Here, Public IP **is converted into** Private IP.
It is used by a client which is inside our private network and want to access the Internet.	It is used when someone from public network wants to access a Server inside the DMZ.
SNAT is performed after the routing decision.	DNAT is performed before the routing decision.
SNAT, can allow one or more than one hosts of private network to get connect to public hosts.	DNAT, allows connection of any host on the public network to a particular host on the private network.

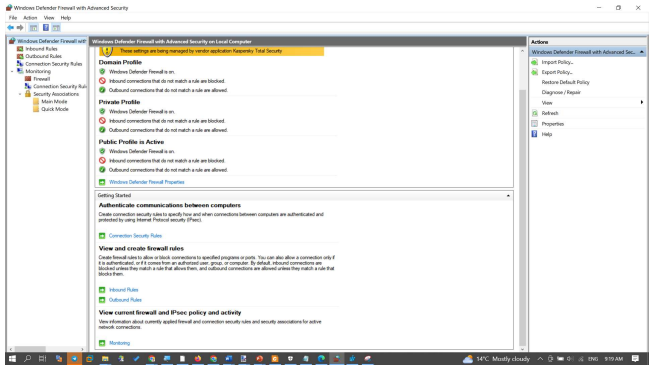
21

Firewall Tableau: Règles de filtrage

	src	port	dst	port	protocol	action
1	any	any	128.12.1.2	25	TCP	permit
2	128.12.1.2	25	any	any	TCP	permit
3	128.12.1.2	any	any	25	TCP	permit
4	any	25	128.12.1.2	any	TCP	permit
5	any	any	any	any	TCP	deny

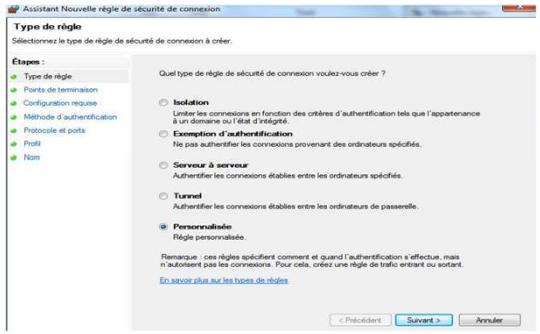
22

Firewall Windows 10



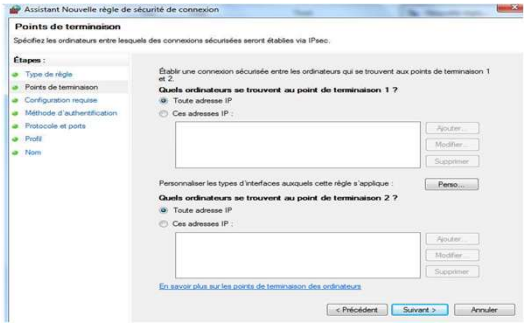
23

Nouvelle règle: type de règle



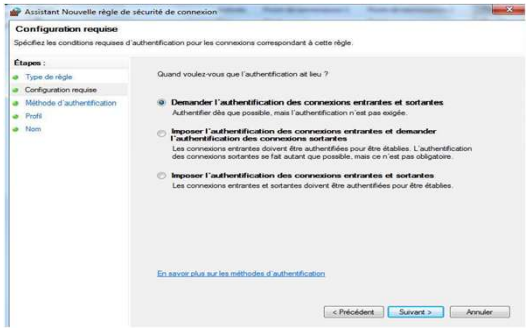
24

Points de terminaison



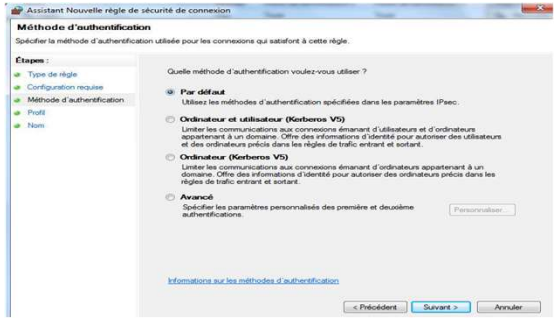
25

Configuration requise



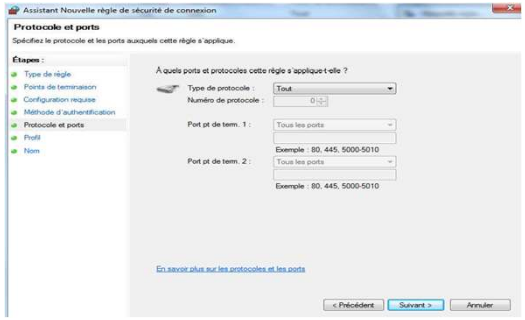
26

Méthode d'authentification



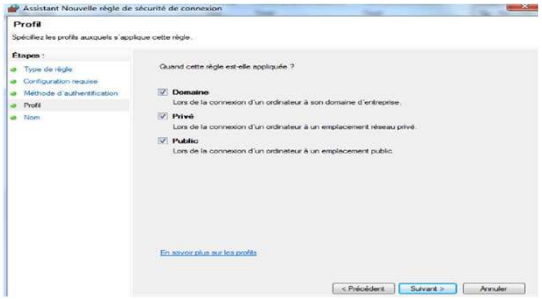
27

Protocole et ports



28

Profil



Iptables

- Effectuer des filtrages de paquets, principalement pour assurer des fonctions de Firewall: interdire , acepeter..
- Effectuer des opérations de NAT (Network Address Translation)
- Effectuer des opérations de marquage des paquets, pour leur appliquer un traitement spécial

Chaines et règles

- Une chaine est une pile de règles
- Chaque règle d'une chaine est composée de deux parties: (un critère et une politique)
- Le critère précise les cas d'application
- Le politique précise l'action accomplie
- Si le critère ne s'applique pas au paquet, on examine la règle suivante
  ==> **l'ordre des règles est important**
- Si aucune règle ne s'applique on examine la politique associée à la chaine.

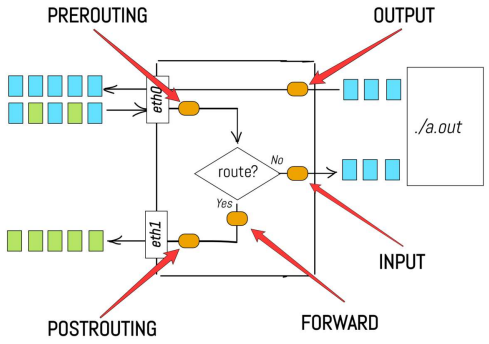
Tables et leurs chaînes

Il existe trois tables qui vont servir à contenir des règles de "filtrage":

- **FILTER**: (INPUT, OUTPUT, FORWORD)
- **NAT**: (PREROUTING, POSTROUTING, OUTPUT)
- **MANGLE**: (PREROUTING, OUTPUT)

Les différentes chaines prédéfinies

- **INPUT**
- **OUTP**
- **FORW**
- **PRER**
  entre c
- **POST**
  après



au

e dès qu'il

afique mais

33

La table "Filter"

- **La chaîne INPUT.**
  Cette chaîne décidera du sort des paquets entrant **localement** sur l'hôte.
- **La chaîne OUTPUT.**
  Ici, ce ne sont que les paquets émis par **l'hôte local** qui seront filtrés
- **La chaîne FORWARD.**
  Enfin, les paquets qui traversent l'hôte, suivant les routes implantées, seront filtrés ici.

```
computer@computer:~$ sudo iptables -t filter --append INPUT -j DROP
computer@computer:~$ ping www.google.com
ping: unknown host www.google.com
computer@computer:~$ sudo iptables -t filter --list
Chain INPUT (policy ACCEPT)
target     prot opt source               destination
DROP       all  --  anywhere             anywhere

Chain FORWARD (policy DROP)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
```

34

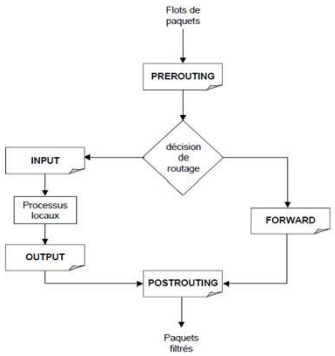
La table NAT

- **La chaîne PREROUTING.**
  Permet de faire de la **translation d'adresse de destination**. Cette méthode est intéressante si l'on veut faire croire au monde extérieur, par exemple, qu'il y a un serveur **WEB sur le port 80** de la passerelle, alors que celui-ci est hébergé par un hôte du réseau privé, **sur le port 8080**.
- **La chaîne POSTROUTING.**
  Elle permet de faire de la **translation d'adresse de la source**, comme du masquage d'adresse, la méthode classique pour connecter un **réseau privé comme client de l'Internet**, avec une seule adresse IP "**officielle**".
- **La chaîne OUTPUT.**
  Celle-ci va permettre de modifier la destination de paquets générés localement (par la passerelle elle-même).

35

La table MANGLE

- Cette table permet le marquage des paquets entrants (**PREROUTING**) et générés localement (**OUTPUT**).



36

Les politiques des règles (Les chaînes)

Les chaînes sont des ensembles de règles que nous allons écrire dans chaque table.

- **ACCEPT**
  Les paquets qui satisfont aux critères sont acceptés, ils continuent leur chemin dans la pile,
- **DROP**
  Les paquets qui satisfont aux critères sont rejetés, on les oublie, on n'envoie même pas de message ICMP .
- **LOG**
  C'est une cible particulière qui permet de tracer au moyen de syslog les paquets qui satisfont aux critères.
- **REJECT** (similaire à DROP, mais avec envoi d'un message d'erreur ICMP à la source du paquet rejeté)
- **RETURN, REDIRECT, SNAT, DNAT, MASQUERADE**...

37

Le DNAT ou NAT Destination

- La chaîne PREROUTING (avant routage) permet de modifier que l'adresse de destination mais conserve l'adresse source.
  C'est ce qu'on appel faire du DNAT (NAT destination).
  Dans cette exemple, on va redireger le trafic en destination du réseau "195.111.222.0" vers le réseau "193.168.1.0".

  iptables -t nat -A PREROUTING -d 195.111.222.0/24 -j DNAT --to-destination 193.168.1.0/24

38

Le SNAT ou NAT Source

- La chaîne POSTROUTING (après routage) permet de modifier que l'adresse source mais conserve l'adresse de destination.
  C'est ce qu'on appel faire du SNAT (NAT source).
  Dans cette exemple, on va substituer l'adresse source du trafic privé sortant vers l'extérieur par une des trois adresses.

  iptables -t nat -A POSTROUTING -s 193.168.1.0/24 -j SNAT --to-source 192.168.1.5-192.168.1.8

39

L'IP Masquerade

- Le principe est d'utiliser une adresse IP publique source pour cacher derrière elle toutes les adresses IP du réseau privé
  - **iptables -t nat -A POSTROUTING -s 193.168.1.0/24 -j SNAT --to-source 192.168.1.199** est équivalent à
  - **iptables -t nat -A POSTROUTING -s 193.168.1.0/24 -j MASQUERADE**
- On peut utilisez d'autres options, comme choisir par rapport a votre interface réseau , ici "eth0" et au numéro de port, dans ce cas "80".
  - **iptables -t nat -A POSTROUTING -o eth0 --dport 80 -j MASQUERADE**

40

La machine d'état

- **NEW:** nouvelle connexion
- **ESTABLISHED:** connexion déjà établie
- **RELATED :** connexion avec une autre déjà établie
- **INVALID**: le paquet invalide

➔En générale ils fonctionnent avec la correspondance **--state**

Création d'une règle

- iptables [-t *table*] commande [correspondance] [cible]

iptables(8) - Linux man page

Name

iptables - administration tool for IPv4 packet filtering and NAT

Synopsis

iptables [-t table] -[AD] chain rule-specification [options]
iptables [-t table] -I chain [rulenum] rule-specification [options]
iptables [-t table] -R chain rulenum rule-specification [options]
iptables [-t table] -D chain rulenum [options]
iptables [-t table] -[LFZ] [chain] [options]
iptables [-t table] -N chain
iptables [-t table] -X [chain]
iptables [-t table] -P chain target [options]
iptables [-t table] -E old-chain-name new-chain-name

Protection contre DDoS et Ping of Death

- **iptables -A INPUT -p icmp --icmp-type echo-request -m limit --limit 1/s -j ACCEPT**
- **iptables -A INPUT -p icmp --icmp-type echo-request -j DROP**
  - **-A INPUT** → pour l'ajout d'une règle au point de filtrage (INPUT, OUTPUT, FORWARD, PREROUTING, POSTROUTING) qu'on appelle aussi chaîne.
  - **-p icmp** → Cible les paquets ICMP (utilisés pour le ping).
  - **--icmp-type echo-request** → Filtre uniquement les requêtes de type "ping".
  - **-m limit --limit 1/s** → Autorise 1 ping par seconde maximum.
  - **-j ACCEPT** → Accepte le ping dans la limite définie.
  - **-j DROP** → Bloque les pings excédentaires

Protection contre les attaques ICMP (Flooding, Smurf Attack)

- **iptables -A INPUT -p icmp -m limit --limit 1/s --limit-burst 3 -j ACCEPT**
- **iptables -A INPUT -p icmp -j DROP**

--limit 1/s --limit-burst 3 → Autorise jusqu'à 3 paquets ICMP en rafale, puis limite à 1 paquet par seconde.

Deuxième règle -j DROP → Bloque tout excès de requêtes ICMP.

Protection contre SYN Flood (Attaque TCP-SYN)

- **iptables -A INPUT -p tcp --syn -m limit --limit 10/s --limit-burst 20 -j ACCEPT**
- **iptables -A INPUT -p tcp --syn -j DROP**

--syn → Cible les paquets de connexion TCP SYN.

--limit 10/s --limit-burst 20 → Autorise 20 connexions simultanées puis limite à 10 par seconde.

-j DROP → Bloque les connexions SYN excessives.

45

Bloquer les paquets fragmentés (utilisés dans certaines attaques DDoS)

- **iptables -A INPUT -f -j DROP**

-f → Cible les paquets fragmentés.

-j DROP → Bloque ces paquets pour éviter les attaques basées sur la fragmentation.

46

Bloquer les paquets avec des adresses IP usurpées (Spoofing)

- **iptables -A INPUT -s 10.0.0.0/8 -j DROP**
- **iptables -A INPUT -s 172.16.0.0/12 -j DROP**
- **iptables -A INPUT -s 192.168.0.0/16 -j DROP**

-s → Spécifie l'adresse source.

Plage IP (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16) → Correspond aux adresses privées qui ne devraient pas apparaître sur Internet.

47

Bloquer une IP spécifique (exemple : adresse d'un attaquant détecté)

- **iptables -A INPUT -s 192.168.1.100 -j DROP**

-s 192.168.1.100 → Bloque tous les paquets provenant de cette IP.

48

Chaîne FORWARD : Gestion du trafic qui traverse la machine

- Autoriser uniquement le trafic HTTP (port 80) qui traverse la machine
  - **sudo iptables -A FORWARD -p tcp --dport 80 -j ACCEPT**
  - **sudo iptables -A FORWARD -j DROP**

49

Chaîne FORWARD : Gestion du trafic qui traverse la machine

- Bloquer les paquets provenant d'une adresse IP spécifique qui transitent par le routeur
  - **sudo iptables -A FORWARD -s 192.168.126.100 -j DROP**

50

Chaîne FORWARD : Gestion du trafic qui traverse la machine

- Limiter le trafic SYN traversant le routeur (contre SYN Flood)
  - **sudo iptables -A FORWARD -p tcp --syn -m limit --limit 5/s --limit-burst 10 -j ACCEPT**
  - **sudo iptables -A FORWARD -p tcp --syn -j DROP**

51

Chaîne OUTPUT : Gestion du trafic sortant depuis la machine

- Bloquer tout ping (ICMP echo-request) sortant de la machine
  - **sudo iptables -A OUTPUT -p icmp --icmp-type echo-request -j DROP**

52

Chaîne OUTPUT : Gestion du trafic sortant depuis la machine

- Limiter les pings sortants à 1 ping par seconde
  - **sudo iptables -A OUTPUT -p icmp --icmp-type echo-request -m limit --limit 1/s -j ACCEPT**
  - **sudo iptables -A OUTPUT -p icmp --icmp-type echo-request -j DROP**

53

Chaîne OUTPUT : Gestion du trafic sortant depuis la machine

- Autoriser uniquement le trafic HTTPS (port 443) pour la machine locale
  - **sudo iptables -A OUTPUT -p tcp --dport 443 -j ACCEPT**
  - **sudo iptables -A OUTPUT -j DROP**

54

Bloquer des plages IP (spoofing protection) sur FORWARD et INPUT

- Règle anti-spoofing pour les adresses privées qui ne doivent pas être routées sur Internet
  - **sudo iptables -A INPUT -s 10.0.0.0/8 -j DROP**
  - **sudo iptables -A INPUT -s 172.16.0.0/12 -j DROP**
  - **sudo iptables -A INPUT -s 192.168.0.0/16 -j DROP**

55

Bloquer Ftp/SSH & @MAC

- ***iptables -A INPUT -p tcp -m multiport --destination-port 21,23 -s ! 127.0.0.1 -j DROP***
  - fermeture des ports des serveurs FTP et de Telnet (le mot de passe circule en clair sur le réseau) [ces deux applications doivent être remplacées par SFTP et SSH]. Avec cette règle, les serveurs FTP et Telnet ne répondent plus, sauf pour les tests en boucle locale (adresse 127.0.0.1).
- ***iptables -A INPUT -p tcp --syn -m limit --limit 10/s -j ACCEPT***
  - limitation du nombre de requêtes d'ouverture de connexion (SYN) à 10 par seconde pour empêcher l'attaque *SYN flooding*.
- ***iptables -A INPUT -p tcp -m mac --mac-source 00:02:B3:98:41:08 –j DROP***
  - Interdiction de toutes les connexions TCP en provenance de la machine dont l'adresse MAC est 00:02:B3:98:41:08. Tous les segments TCP sont rejetés.

56